

CYBER SECURITY TASK 1 · 2026

Web Application Security Assessment

Target: demo.testfire.net

Field	Detail
Prepared by	Idrisa Haruni Kigaile
Program	Future Interns · Cyber Security Task 1 (2026)
Assessment type	Passive reconnaissance + automated vulnerability scan (non-intrusive)
Tools used	nslookup, whois, Nmap 7.98, curl, OWASP ZAP by Checkmarx 2.17.0
Target IP	65.61.137.117 (ports 80, 443, 8080 open)
Scan date	27 July 2026
Report date	28 July 2026
Total findings	15 alerts — 0 High, 4 Medium, 7 Low, 4 Informational

Prepared for a non-technical audience: every finding below is explained in plain language, rated by risk, and paired with clear steps to fix it.

Table of Contents

1. Executive Summary	4
2. Findings at a Glance	4
Top three priorities	4
3. Information Gathering (Reconnaissance)	5
4. Identified Vulnerabilities	7
5. Findings in Detail	9
F-01 · Absence of Anti-CSRF Tokens	9
What it means	9
How to fix it	9
F-02 · Content Security Policy (CSP) Header Not Set	9
What it means	9
How to fix it	9
F-03 · Missing Anti-clickjacking Header	10
What it means	10
How to fix it	10
F-04 · Sub Resource Integrity Attribute Missing	10
What it means	10
How to fix it	10
F-05 · Cookie without SameSite Attribute	10
What it means	10
How to fix it	10
F-06 · Cross-Domain JavaScript Source File Inclusion	11
What it means	11
How to fix it	11
F-07 · Information Disclosure – Debug Error Messages	11
What it means	11
How to fix it	11
F-08 · Server Leaks Version Information via "Server" Header	11
What it means	11
How to fix it	11
F-09 · Strict-Transport-Security Header Not Set	12
What it means	12
How to fix it	12
F-10 · Timestamp Disclosure – Unix	12
What it means	12
How to fix it	12
F-11 · X-Content-Type-Options Header Missing	13
What it means	13
How to fix it	13
F-12 · Information Disclosure – Suspicious Comments	13

What it means.....	13
How to fix it.....	13
F-13 · Retrieved from Cache.....	13
What it means.....	13
How to fix it.....	13
F-14 · Modern Web Application.....	14
What it means.....	14
How to fix it.....	14
F-15 · Session Management Response Identified.....	14
What it means.....	14
How to fix it.....	14
6. Remediation Roadmap.....	14
7. Scope and Limitations.....	15

1. Executive Summary

I examined the public-facing website **demo.testfire.net** to see what information it reveals about itself and whether its security settings are configured correctly. Testing was **passive and safe** no data was changed and no attacks were carried out.

The good news: no critical, immediately exploitable weaknesses were detected by the automated scan.

The concern: The site is missing most of the standard protective settings that modern websites use. On their own these gaps are not catastrophic, but together they make common attacks such as tricking a logged-in user into performing an action they did not intend, or hijacking a session noticeably easier. The server also openly advertises the exact software version it runs (Apache Tomcat/Coyote 1.1, a very old release) and the login page is served over unencrypted HTTP.

2. Findings at a Glance

Risk level	Findings	What it means
High	0	Fix immediately — direct route to compromise
Medium	4	Fix soon — meaningfully increases chance of a successful attack
Low	7	Fix when convenient — helps an attacker prepare
Informational	4	No action strictly required — useful context

Top three priorities

1. Add anti-CSRF (request forgery) protection to all forms, especially the login form.
2. Add the missing security headers (CSP, X-Frame-Options, HSTS, X-Content-Type-Options).
3. Force all traffic to HTTPS and stop the server from revealing its software version.

3. Information Gathering (Reconnaissance)

Before scanning, I collected publicly available details about the target. Anyone on the internet can do the same which is exactly why it matters what a server chooses to reveal.

Check	What found	Why it matters
DNS lookup (nslookup)	demo.testfire.net resolves to 65.61.137.117	Confirms the single server hosting the site; normal and expected.
Domain records (whois)	No public registration record returned for the domain	Little owner information leaks this is good practice.
Port & service scan (Nmap)	80/tcp open – HTTP (Apache Tomcat/Coyote 1.1) 443/tcp open – HTTPS 8080/tcp open – HTTP (Tomcat/Coyote 1.1) 8443/tcp closed · 996 ports filtered	Port 8080 duplicates the website on a non-standard port and widens the attack surface. The exact server software and version are advertised.
Certificate check	Sectigo RSA 2048-bit certificate for demo.testfire.net, expired 21 June 2026	An expired certificate makes browsers warn visitors and trains users to ignore security warnings.
Response headers (curl)	Server: Apache-Coyote/1.1 Set-Cookie: JSESSIONID=...; Path=/; HttpOnly No HSTS, CSP, X-Frame-Options or X-Content-Type-Options	HttpOnly on the session cookie is positive, but Secure and SameSite are absent and protective headers are missing entirely.

```
kigaile@kigaileID:~$ nslookup demo.testfire.net
```

```
Server:      127.0.0.53
```

```
Address:     127.0.0.53#53
```

```
Non-authoritative answer:
```

```
Name:   demo.testfire.net
```

```
Address: 65.61.137.117
```

```
kigaile@kigaileID:~$ whois demo.testfire.net
```

```
No match for "DEMO.TESTFIRE.NET".
```

```
>>> Last update of whois database: 2026-07-27T13:24:28Z <<<
```

NOTICE: The expiration date displayed in this record is the date the registrar's sponsorship of the domain name registration in the registry is currently set to expire. This date does not necessarily reflect the expiration date of the domain name registrant's agreement with the sponsoring registrar. Users may consult the sponsoring registrar's Whois database to view the registrar's reported date of expiration for this registration.

TERMS OF USE: You are not authorized to access or query our Whois database through the use of electronic processes that are high-volume and automated except as reasonably necessary to register domain names or modify existing registrations; the Data in VeriSign Global Registry Services' ("VeriSign") Whois database is provided by VeriSign for information purposes only, and to assist persons in obtaining information about or related to a domain name registration record. VeriSign does not guarantee its accuracy. By submitting a Whois query, you agree to abide by the following terms of use: You agree that you may use this Data only for lawful purposes and that under no circumstances will you use this Data to: (1) allow, enable, or otherwise support the transmission of mass unsolicited, commercial advertising or solicitations via e-mail, telephone, or facsimile; or (2) enable high volume, automated, electronic processes that apply to VeriSign (or its computer systems). The compilation, repackaging, dissemination or other use of this Data is expressly prohibited without the prior written consent of VeriSign. You agree not to use electronic processes that are automated and high-volume to access or query the Whois database except as reasonably necessary to register domain names or modify existing registrations. VeriSign reserves the right to restrict your access to the Whois database in its sole discretion to ensure operational stability. VeriSign may restrict or terminate your access to the Whois database for failure to abide by these terms of use. VeriSign reserves the right to modify these terms at any time.

The Registry database contains ONLY .COM, .NET, .EDU domains and Registrars.

```
kigaile@kigaileID:~$
```

```
kigaile@kigaileID:~$ nmap -sV -T3 -Pn demo.testfire.net
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-27 16:30 +0300
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up (0.24s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache Tomcat/Coyote JSP engine 1.1
443/tcp   open  ssl/https?
8080/tcp   open  http      Apache Tomcat/Coyote JSP engine 1.1
8443/tcp   closed https-alt

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 31.23 seconds
kigaile@kigaileID:~$ nmap -p 80,443 --script=http-headers,http-title,ssl-cert demo.testfire.net
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-27 16:32 +0300
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up (0.24s latency).

PORT      STATE SERVICE
80/tcp    open  http
| http-headers:
|   Server: Apache-Coyote/1.1
|   Set-Cookie: JSESSIONID=95F95FB48D3D070ED8D4FE9788236D13; Path=/; HttpOnly
|   Content-Type: text/html; charset=ISO-8859-1
|   Transfer-Encoding: chunked
|   Date: Mon, 27 Jul 2026 13:32:17 GMT
|   Connection: close
|
|_ (Request type: HEAD)
| http-title: Altoro Mutual
443/tcp    open  https
| ssl-cert: Subject: commonName=demo.testfire.net
| Subject Alternative Name: DNS:demo.testfire.net
| Issuer: commonName=Sectigo RSA Domain Validation Secure Server CA/organizationName=Sectigo Limited/stateOrProvinceName=Greater Manchester/countryName=GB
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2025-05-21T00:00:00
| Not valid after: 2026-06-21T23:59:59
| MD5: 04a1 2772 0069 3d65 011d ded8 ccb0 201c
| SHA-1: a1e9 8d60 388b 84f4 bbc5 50d7 b61b b2b0 cc89 61fd
|_ SHA-256: b0ea c225 501d b594 a963 9f9e 718b c036 759b 9f49 2c7c 729a 60c8 4735 6839 3382

Nmap done: 1 IP address (1 host up) scanned in 4.75 seconds
kigaile@kigaileID:~$
```

```
kigaile@kigaileID:~$ curl -I http://demo.testfire.net
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Set-Cookie: JSESSIONID=1C912167EB2E4FAFF24C6652FA6A0085; Path=/; HttpOnly
Content-Type: text/html; charset=ISO-8859-1
Transfer-Encoding: chunked
Date: Mon, 27 Jul 2026 13:39:09 GMT

kigaile@kigaileID:~$
```

4. Identified Vulnerabilities

Each finding lists the risk rating, a plain-English explanation, and the steps needed to resolve it.

ID	Finding	Risk	Where observed
F-01	Absence of Anti-CSRF Tokens	Medium	3 pages (incl. /login.jsp)
F-02	Content Security Policy (CSP) Header Not Set	Medium	3 pages
F-03	Missing Anti-clickjacking Header	Medium	3 pages
F-04	Sub Resource Integrity Attribute Missing	Medium	/index.jsp?content=personal_investments.htm
F-05	Cookie without SameSite Attribute	Low	3 cookies (JSESSIONID)
F-06	Cross-Domain JavaScript Source File Inclusion	Low	/index.jsp?content=personal_investments.htm
F-07	Information Disclosure – Debug Error Messages	Low	/swagger/properties.json
F-08	Server Leaks Version Information via "Server" Header	Low	5 responses (Apache-Coyote/1.1)
F-09	Strict-Transport-Security Header Not Set	Low	2 responses
F-10	Timestamp Disclosure – Unix	Low	3 responses
F-11	X-Content-Type-Options Header Missing	Low	7 responses
F-12	Information Disclosure – Suspicious Comments	Informational	6 responses (incl. /login.jsp)
F-13	Retrieved from Cache	Informational	4 responses
F-14	Modern Web Application	Informational	4 responses
F-15	Session Management Response Identified	Informational	3 responses

5. Findings in Detail

F-01 · Absence of Anti-CSRF Tokens

Risk	Where observed	Reference
Medium	3 pages (incl. /login.jsp)	CWE-352

What it means

The site's forms do not include a hidden, one-time security code that proves the request really came from the site itself. Without it, an attacker can build a booby-trapped page; if a logged-in user visits it, their browser can be made to submit a request (for example a transfer or a settings change) without them realising.

How to fix it

1. Generate a unique anti-CSRF token per user session and include it as a hidden field in every form that changes data.
2. Reject any submission where the token is missing or does not match.
3. Set the session cookie to SameSite=Strict (or Lax) as a second line of defence.
4. Use the framework's built-in CSRF protection rather than a custom implementation.

F-02 · Content Security Policy (CSP) Header Not Set

Risk	Where observed	Reference
Medium	3 pages	CWE-693

What it means

The site does not tell the browser which sources of scripts, images and styles are allowed. If an attacker manages to inject malicious code into a page, the browser will happily run it because there is no allow-list to stop it.

How to fix it

1. Add a Content-Security-Policy response header, starting in report-only mode to spot breakages.
2. Define a strict allow-list, e.g. default-src 'self'; script-src 'self'; object-src 'none'; frame-ancestors 'none'.
3. Remove inline scripts and inline event handlers so 'unsafe-inline' is not needed.
4. Monitor CSP violation reports, then switch from report-only to enforcing.

F-03 · Missing Anti-cslickjacking Header

Risk	Where observed	Reference
Medium	3 pages	CWE-1021

What it means

Another website can load this site invisibly inside its own page and overlay fake buttons. A user thinks they are clicking something harmless while they are actually clicking inside the real site for example approving a payment.

How to fix it

1. Send X-Frame-Options: DENY (or SAMEORIGIN if framing by your own pages is required).
2. Preferably add frame-ancestors 'none' to the Content-Security-Policy header, which supersedes X-Frame-Options.
3. Apply the header site-wide at the web-server or load-balancer level so no page is missed.

F-04 · Sub Resource Integrity Attribute Missing

Risk	Where observed	Reference
Medium	/index.jsp? content=personal_investments. htm	CWE-345

What it means

The page loads a script hosted on someone else's server without checking that the file is unchanged. If that third party is ever hacked, malicious code would run on this site automatically.

How to fix it

1. Add an integrity="sha384-..." attribute plus crossorigin="anonymous" to every externally hosted script and stylesheet.
2. Where possible, host critical third-party files locally instead.
3. Re-generate the hash whenever the third-party file is intentionally updated.

F-05 · Cookie without SameSite Attribute

Risk	Where observed	Reference
Low	3 cookies (JSESSIONID)	CWE-1275

What it means

The session cookie does not say whether it may be sent when the request comes from another website. Browsers may therefore attach it to cross-site requests, which is what makes request-forgery attacks work.

How to fix it

1. Set SameSite=Strict on the session cookie (use Lax only if cross-site links must stay logged in).
2. Also set the Secure flag so the cookie is only ever sent over HTTPS.
3. Keep the existing HttpOnly flag — it is already correctly applied.

F-06 · Cross-Domain JavaScript Source File Inclusion

Risk	Where observed	Reference
Low	/index.jsp? content=personal_investments. htm	CWE-829

What it means

The site runs JavaScript downloaded from a domain it does not control. That external party effectively has full control over what happens on the page.

How to fix it

1. Review every external script and remove any that is not strictly necessary.
2. Self-host the remaining scripts, or pin them with Subresource Integrity (see F-04).
3. Restrict allowed script sources with the CSP script-src directive.

F-07 · Information Disclosure – Debug Error Messages

Risk	Where observed	Reference
Low	/swagger/properties.json	CWE-1295

What it means

The application returns detailed technical error text. These messages can reveal file paths, database details and internal logic, giving an attacker a free map of the system.

How to fix it

1. Turn off debug/verbose error output in the production configuration.
2. Show users a generic error page and log the technical detail server-side only.
3. Restrict or remove publicly reachable diagnostic endpoints such as /swagger/.

F-08 · Server Leaks Version Information via "Server" Header

Risk	Where observed	Reference
Low	5 responses (Apache-Coyote/1.1)	CWE-497

What it means

Every response announces the exact web-server software and version. Attackers simply look up known exploits for that version instead of having to probe for weaknesses.

How to fix it

1. Suppress or generalise the Server header (in Tomcat set the server attribute on the HTTP Connector; in Apache use ServerTokens Prod).
2. Remove other identifying headers such as X-Powered-By.
3. Upgrade Tomcat/Coyote to a currently supported release — 1.1 is long out of support.

F-09 · Strict-Transport-Security Header Not Set

Risk	Where observed	Reference
Low	2 responses	CWE-319

What it means

The site does not instruct browsers to always use the encrypted (HTTPS) version. A visitor's first request can travel in plain text and be intercepted or redirected on an untrusted network such as public Wi-Fi.

How to fix it

1. Redirect all HTTP traffic to HTTPS with a 301 response.
2. Send Strict-Transport-Security: max-age=31536000; includeSubDomains (add preload once verified).
3. Renew the TLS certificate — the current one expired on 21 June 2026 — and automate future renewals.
4. Disable or restrict the duplicate HTTP service on port 8080.

F-10 · Timestamp Disclosure – Unix

Risk	Where observed	Reference
Low	3 responses	CWE-497

What it means

Raw timestamps are exposed in page content. Alone this is harmless, but it can help an attacker guess how identifiers or tokens are generated.

How to fix it

1. Remove unnecessary timestamps from responses sent to the browser.
2. Never derive session IDs, tokens or passwords from predictable values such as the current time.

F-11 · X-Content-Type-Options Header Missing

Risk	Where observed	Reference
Low	7 responses	CWE-693

What it means

Without this header a browser may ignore the declared file type and guess instead. A file uploaded as an image could end up being executed as a script.

How to fix it

1. Add X-Content-Type-Options: nosniff to all responses.
2. Make sure every response declares a correct and specific Content-Type.

F-12 · Information Disclosure – Suspicious Comments

Risk	Where observed	Reference
Informational	6 responses (incl. /login.jsp)	CWE-615

What it means

Developer notes left in the page source (words such as TODO, FIXME, admin) are visible to anyone who views the page source and may hint at unfinished or weak areas.

How to fix it

1. Strip comments from production HTML, CSS and JavaScript during the build.
2. Review the flagged comments and remove any that reference credentials, internal hosts or known issues.

F-13 · Retrieved from Cache

Risk	Where observed	Reference
Informational	4 responses	CWE-525

What it means

Some content was served from a cache. If sensitive pages are cached, they could be read later from a shared browser or proxy.

How to fix it

1. Send Cache-Control: no-store, no-cache, must-revalidate on authenticated and sensitive pages.
2. Allow caching only for genuinely public static assets.

F-14 · Modern Web Application

Risk	Where observed	Reference
Informational	4 responses	—

What it means

The scanner simply noted that the site uses JavaScript-driven pages. This is not a weakness.

How to fix it

1. No action required. Note that automated scanners may miss JavaScript-generated pages, so complement scanning with manual testing.

F-15 · Session Management Response Identified

Risk	Where observed	Reference
Informational	3 responses	—

What it means

The scanner recognised the standard Java session cookie (JSESSIONID). This confirms sessions are in use.

How to fix it

1. No action required. Ensure session IDs are regenerated at login and invalidated at logout, with a sensible idle timeout.

6. Remediation Roadmap

Priority	Timeframe	Actions
1 — Now	0–2 weeks	Anti-CSRF tokens on all forms (F-01); SameSite + Secure on session cookies (F-05); renew the expired TLS certificate and force HTTPS with HSTS (F-09).
2 — Soon	2–6 weeks	Deploy CSP (F-02); X-Frame-Options / frame-ancestors (F-03); X-Content-Type-Options (F-11); disable debug errors and lock down /swagger/ (F-07).
3 — Planned	6–12 weeks	Upgrade Tomcat and suppress version headers (F-08); add Subresource Integrity and reduce third-party scripts (F-04, F-06); close or restrict port 8080; strip comments and timestamps from output (F-10, F-12); tighten cache headers (F-13).
4 — Ongoing	Continuous	Re-scan after each change, add security-header checks to the release process, and schedule manual testing for logic flaws automated tools cannot see.

7. Scope and Limitations

Testing was passive and automated. Automated scanners cannot detect business-logic flaws, broken access control between accounts, or issues behind authentication that were not crawled; a manual penetration test is recommended to complete the picture. Alerts relating to third-party Mozilla CDN hosts observed during the scan are outside the scope of this target and are excluded from the counts above. demo.testfire.net is a deliberately vulnerable demonstration application published by its owner for training purposes; all testing was carried out for educational use.